PLUGIN-AUDIT · 12. NOVEMBER 2026

Plugin-audit 12/11 2026

Steamgears Autopilot 7.76.1

Kilde: plugins/steamgears-autopilot · release: steamgears-autopilot-v7.76.1.zip · roadmap: ROADMAP.md

Auditten startede på **7.76.0** og endte i **7.76.1**. Den er en statisk og testbaseret gennemgang: pluginets PHP-filer, lint på PHP 8.5.8 og hele smoke-suiten med stubbet WordPress. Der er **ikke** kørt integrationstest mod WordPress/MySQL, og intet er ændret på det levende site — releasen kræver ejerens «Plugins → Update»-klik.

7.76.0 havde allerede publish-log-tabellen og en Re-queue-knap. Det denne runde retter er de steder, hvor REST-laget, kvalitetsgaten og uninstall stadig ikke fulgte med.

Metode

Flade	Hvad der blev gjort
Syntaks	php -l på de ændrede plugin- og testfiler
Adfærd	php plugins/tests/smoke.php — 1562 PASS / 0 FAIL (1550 før)
REST	Gennemgang af ruter, permissions, inputvalidering og svar på ukendte id'er
Database	Gennemgang af $wpdb-kald, prepare(), tabelnavne og oprydning
Drift	Cron-hooks, uninstall, postmeta og publiceringskæden (kø → pre-flight → Publer/RSS)
Release	Zip bygget fra kilden og sammenlignet med diff -r

Fund og rettelser

#	Alvor	Fund	Rettelse
1	Høj	scheduled_at blev kørt gennem strtotime()/wp_date(), så en oplyst site-tid blev flyttet med sitets UTC-offset. En umulig dato som 2026-02-31 blev normaliseret til en anden dag.	SGAP_Queue::schedule() validerer wall-clock og bevarer site-tiden. Ugyldig dato giver 400, ikke “nu”.
2	Høj	(bool) $param gjorde force=false og remind=false sande, fordi strengen "false" er truthy i PHP. Et form-request kunne dermed omgå quality-gaten eller sende en reminder som en almindelig post.	SGAP_REST::flag() accepterer kun true, 1, yes og on; alt andet er falsk.
3	Mellem	POST /drafts/<id>/status svarede 200 på et ukendt id, fordi $wpdb->update() returnerer 0 og ikke false. Kalderen kunne tro at en draft var opdateret.	Slår id op først og svarer 404 ved ukendt draft.
4	Mellem	Der var ingen REST-vej til at prøve en fejlet post igen; kun admin-knappen.	POST /queue/<id>/status accepterer nu status=queued, som genbruger SGAP_Queue::retry() og nulstiller attempts, error, external id og reminder. Admin-knappen bruger samme metode.
5	Mellem	Kvalitetsgaten behandlede enhver query-streng som et arkiv. Et dødt produktlink med ?utm_source=… slap derfor igennem som “arkiv”.	Kun arkiv-parametre (s, paged, page, orderby, preview, replytocom, …) gør et link til et arkiv; tracking-parametre gør ikke. ?p=123 er stadig en enkelt post.

#	Alvor	Fund	Rettelse
6	Mellem	Uninstall slettede kun fire navngivne _sgap_*-nøgler. Evergreen-markeringer, AI-billeder, studio-data, niche-markører og attributionsnøgler blev liggende efter pluginnet var fjernet.	Uninstall sletter nu alle _sgap_*-postmeta via esc_like() og prepare().
7	Lav	Uninstall ryddede ikke sgap_evergreen, sgap_coach_learn, sgap_rescue og sgap_cirla_daily.	Alle fire står nu i uninstall-listen.
8	Lav	SGAP_Install::TABLES og /snapshot manglede sgap_publish_log og sgap_reddit_posts, så en manglende tabel blev ikke rapporteret.	Begge lister kender nu alle ti tabeller.

Udvidelser, der følger af fundene

- **status=queued på /queue/<id>/status** er en lille, bagudkompatibel udvidelse: et eksternt dashboard kan nu genstarte en fejlet post uden at kende admin-URL'en. Den rører ikke published- eller sending-rækker, og den rydder reminder-flaget, fordi “prøv igen” betyder “lad autopiloten prøve”.
- **Én fælles retry-vej** i `SGAP_Queue::retry()` betyder at admin-knappen og REST gør præcis det samme.
- **Wall-clock-validering** er nu delt mellem REST og køen, så en intern kalder ikke kan omgå den.

Verifikation

- `php plugins/tests/smoke.php` → **1562 PASS / 0 FAIL**, exit 0.
- `php -l` på de ændrede filer → ingen syntaksfejl.
- `diff -r plugins/steamgears-autopilot /tmp/sgap-zip-check-7761/steamgears-autopilot` → **ingen forskel**.
- Zip: `plugins/steamgears-autopilot-v7.76.1.zip`, version 7.76.1 i både header og `SGAP_VERSION`.
- `python3 tools/patch_notes.py --check` → grøn (kør efter zip-byg).
- `python3 projektstatus.py --check` → 10 projekter, ingen drift.
- **Ikke kørt:** integrationstest mod rigtigt WordPress/MySQL, live REST-kald, browser, Lighthouse. Derfor er release kun verificeret på kilde-, lint-, smoke- og zip-niveau.

Forslag til næste pas (ikke bygget)

1. **Integrationstests for de nye REST-tilfælde.** Smoke-testen beviser logikken med stubs; en rigtig WordPress-kørsel bør bekræfte at `scheduled_at` bevarer site-tiden, at `force=false` afvises af quality-gaten, og at `status=queued` giver 200/404 som forventet. Det er den næste sikre udvidelse af `plugins/tests/integration.php`.
2. **Test af uninstall mod rigtig database.** Kontrollér at alle `_sgap_*`-meta og alle cron-hooks faktisk er væk efter «Delete», ikke kun at kilden indeholder den rigtige SQL.
3. **Race ved dublet-værn.** `fingerprint` er et almindeligt index, ikke unikt, fordi reglerne afhænger af status og alder. To samtidige skrivninger kan derfor begge passere `find()` før `insert()`. Et transaktions- eller advisory-lock omkring `SGAP_Queue::add()` vil lukke det; det kræver en bevidst beslutning om låseomkostningen.
4. **Publish-log i /snapshot.** Tabellen tjekkes nu for manglende tabel, men selve loggen er ikke med i snapshotet. Et `publish_log_tail` med de seneste 50 rækker ville gøre Command Center i stand til at vise “hvorfor fejlede det” uden et ekstra admin-kald.
5. **Action Scheduler** til publicerings-ticken, hvis WP-Cron på det cachede site fortsat giver forsinkelser. Det er den større, korrekte løsning på P0.4, men den er ikke nødvendig for denne

fejlretning.

6. **Ejerbeslutning om labor_rate.** Det er stadig den eneste registrerede, ulæste indstilling. Skjul den, eller brug den i ROI; begge er en forretningsbeslutning, ikke en kodningsopgave.

Grænser

- Der er ingen browser, MySQL eller WordPress i sandkassen, så live-adfærd og integration er ikke målt.
- Smoke-suiten bruger stubbet `$wpdb`; den beviser kontrolflow og SQL-form, ikke rigtig MySQL-adfærd.
- Zip’en er byte-identisk med kilden, men er ikke installeret på steamgears.eu.